STRIDE findings summary (counts are formulas over the Findings sheet)

By priority	Count
High	5
Medium	12
Low	6
Total	**23**

By STRIDE category	Count
Spoofing	5
Tampering	5
Repudiation	2
Information disclosure	4
Denial of service	4
Elevation of privilege	**3**
Total	**23**

Notes

Source: STRIDE analysis of home-assistant-system-package.docx and home-assistant-diagrams.pdf only;
Ranks are dense: findings with the same rank are judged equally important.
Rank 1 is highest priority. The coverage sheet is not part of the finding count.
Findings marked with an additional assumption depend on a premise the package does not establish.

no outside sources used.

Rank	Finding ID	Affected component / data flow	Primary STRIDE
1	F-01	P6 Custom integration inside Core (DF17); DS1, DS2, DS3, DS6	Elevation of privilege
2	F-02	DF2 Frontend to Core APIs (P1 to P2)	Information disclosure
2	F-03	DF3 EE6 to P2 (long-lived token)	Information disclosure
3	F-04	DF2 and P1 (frontend load and API calls)	Tampering
3	F-05	EE1 Household administrator (login via DF2 to P2)	Spoofing
4	F-06	EE6 Local script holding long-lived token	Spoofing
4	F-07	DF10 Pairing request and DF8 joining frames (P4, P5)	Spoofing
5	F-08	EE4 Zigbee end devices	Information disclosure
5	F-09	EE4 sensors and DF8 reports (to P4, then DF14 and DS4)	Spoofing
5	F-10	EE3 plug and bulb, DF9 mesh relay and DF8	Tampering
6	F-11	DS7 Local application logs (DF18)	Repudiation
6	F-12	DS5 Encrypted backup archive and P7 (DF16)	Tampering
6	F-13	DS5 backups and live stores DS1-DS4 (DF16, DF17)	Denial of service
7	F-14	P2 admin-only authorization (TB4, DF2)	Elevation of privilege
7	F-15	EE5 Manufacturer OTA provider and DF11	Tampering
7	F-16	P2 Core APIs (shared with P3, P4) via DF2 and DF3	Denial of service
7	F-17	P2 login (DF2) for EE1 and EE2 accounts	Spoofing
8	F-18	P3 Automation engine and DF5	Elevation of privilege
8	F-21	EE4 end devices, DF8	Denial of service
9	F-19	P2, DF3 and DS7 (attribution)	Repudiation

9	F-20	P2 login throttling (DF2)	Denial of service
9	F-22	EE3 plug and bulb via DF1, DF6	Tampering
9	F-23	DF8 and DF9 Zigbee radio traffic	Information disclosure

Threat mechanism and consequence
The integration shares Core's process and privileges, so TB4 is not enforced against it. It can read integration secrets, token records, the Zigbee network key and the backup key (which also decrypts DS5). It can also drive P2 and P4 to control devices, giving full control of Core and the Zigbee network.
Cleartext HTTP/WS exposes login passwords, refresh and access tokens, and live occupancy and door events. A captured token is replayed to hijack a session, including an administrator's.
The script sends its long-lived token in every cleartext HTTP call. A captured token can be replayed from any LAN host as the script, with the owner's authority, until someone notices and revokes it.
With no TLS, an active on-path attacker can inject script into the frontend load, alter requests and responses, or impersonate Core to harvest credentials. This yields actions inside an administrator or user session.
With stolen administrator credentials and no MFA, the attacker logs in from any LAN host. They can open pairing (DF10), start OTA installs (DF11), edit automations and configuration, and mint new tokens.
An attacker who reads the token from the script's storage impersonates the script without any interactive login.
Joining is conventional, with no install codes. An attacker device that answers a join during the 60-second window can be accepted as a legitimate device and receive the network key.
Brief physical access to an end device is used to extract the shared network key from its key material, which compromises the whole mesh.
A key holder forges door and motion reports. This falsifies DS4 history and triggers or suppresses P3 automations. Encryption gives no per-device authorization among key holders.
A key holder injects or alters frames to actuate the plug and bulb, or selectively drops relayed traffic. This causes unauthorized control or loss of control of devices.
The malicious integration edits or deletes authentication, integration and backup events. With no central or off-host archive, the evidence is gone and its own actions can be denied.
Using the locally stored key (DS6), the integration crafts or replaces an archive containing attacker accounts, tokens or automations. A later restore reinstalls the backdoor after the integration is removed.
A Core-privileged writer deletes or corrupts live data and the only backups. With no off-host copy, configuration, accounts and Zigbee state are lost, and every device must be re-paired. The offline recovery key is useless without an archive.
An ordinary user calls an admin-only REST or WebSocket action directly (for example pairing, OTA or token creation) instead of through the UI.
A malicious image or metadata served through the configured provider path is accepted, because no signature check is credited. After the administrator installs it, devices that hold the network key are persistently compromised.
Request or connection flooding stalls P2. Because P2, P3 and P4 share a process, automations and Zigbee control stall too.
Throttling slows but does not stop online guessing or credential stuffing, and there is no MFA. A hit gives that user's session.
An ordinary user triggers an automation that performs actions beyond that user's own rights, since automations issue commands with Core authority.
Jamming or frame flooding from outside the home silences or drains the battery sensors, so door and motion events are lost.
DF18 records authentication, integration and backup events. A holder of the long-lived token, or a user issuing device commands, cannot be told apart from the script or the legitimate user afterwards.

Deliberate failed logins trip throttling and lock out the administrator or a user.
An ordinary user, or someone holding a hijacked ordinary session, operates any configured device because there is no per-device allowlist.
Timing and frequency of encrypted frames from the door and motion sensors reveal when the home is occupied.

Required initial attacker access	Additional assumption	Priority
Malicious community integration running in Core	None	**High**
Untrusted LAN guest or compromised LAN device	Attacker can observe client-to-Core traffic (an on-path position on the flat LAN; the package does not say how traffic becomes visible)	**High**
Untrusted LAN guest or compromised LAN device	Same on-path assumption as F-02	**High**
Untrusted LAN guest or compromised LAN device	Attacker can actively redirect or modify LAN traffic, and a user loads the frontend	**High**
Stolen administrator credentials	None	**High**
Compromised LAN device	The compromised device is EE6's host, or the script's storage is readable there (protection on EE6 is not stated)	**Medium**
Nearby radio attacker able to receive and transmit	Attacker detects the open window and completes a join, and the administrator cannot tell the joiner is not their device	**Medium**
Brief physical access to an end device	Extraction succeeds, which the package explicitly says is not established	**Medium**
Possession of the Zigbee network key	The key was obtained (via F-07 or F-08), and forged frames are accepted despite frame-counter checks	**Medium**
Possession of the Zigbee network key	Same as F-09	**Medium**
Malicious community integration	None	**Medium**
Malicious community integration	The administrator later restores that archive, and restore checks nothing beyond decryption	**Medium**
Malicious community integration	None	**Medium**
Ordinary household user	At least one administrator check is missing or inconsistent server-side (the package credits these checks, so this is not established)	**Medium**
Attacker able to influence content on the provider path	Provider content or endpoint is compromised from outside (provider insiders are out of scope), and the administrator starts the install	**Medium**
Untrusted LAN guest or compromised LAN device	No rate or connection limits beyond login throttling (the package is silent on this)	**Medium**
Untrusted LAN guest or compromised LAN device	Weak or reused password, or throttling permits enough attempts (the attempt count is not stated)	**Medium**
Ordinary household user	Such an automation exists and the user can trigger it	**Low**
Nearby radio attacker	Unauthenticated traffic can block or drain the sensors	**Low**
Token holder or ordinary user	Device commands and administrator actions are not attributed per actor in DS4 or DS7	**Low**

Untrusted LAN guest	Throttling is per account, not per source	**Low**
Ordinary household user	The household expects some devices to be off-limits to ordinary members	**Low**
Nearby radio attacker (receive only)	Frame timing correlates with real events	**Low**

Priority justification
No isolation, impact covers nearly every asset, and it is an in-scope attacker.
Plaintext is a stated deployment choice, the LAN is flat, and administrator traffic is included.
The token does not expire and the script is administrator-owned. Separate from F-02 because of its lifetime and revocation dependence.
Impact is session or credential takeover. Needs an active position, somewhat harder than F-02.
A single factor gives all administrator authority, and admin-only actions chain into the radio and firmware paths.
The assumption limits likelihood, but the result is persistent and bypasses interactive login.
Window is brief and rare, but it yields the network-wide key.
Impact is network-wide, but the extraction premise is unproven.
Consequence is falsified security state, but depends on first getting the key.
Moderate physical effect, dependent on key compromise.
Weakens detection and forensics rather than causing direct harm.
Gives persistence across cleanup, but needs a restore event.
Recovery is costly, and it is a single failure domain by design.
High impact if it exists, but the control is stated as present.
Persistent impact, but demanding preconditions. HTTPS blocks LAN-level tampering.
Easy to attempt from the LAN, but ends when the flood stops.
Throttling is a real control. Risk is highest for the administrator account.
Entirely configuration-dependent.
Only two sensors, lasts only while the attacker is nearby, and no data is compromised.
The package does not establish that these records are missing.

Temporary, with no data impact.
Matches the stated design, so it is a least-privilege gap, not a bypass.
Yields coarse presence information only, and radio access alone grants no key.

Element type	ID	Name / endpoints
External entity	EE1	Household administrator
External entity	EE2	Ordinary household member
External entity	EE3	Zigbee routers smart plug and bulb
External entity	EE4	Zigbee end devices door and motion sensors
External entity	EE5	Manufacturer OTA provider
External entity	EE6	Local script holding long lived token
Process	P1	Frontend on browser or phone
Process	P2	Core APIs authentication state machine and event bus
Process	P3	Automation engine inside Core
Process	P4	ZHA inside Core
Process	P5	USB coordinator firmware
Process	P6	Custom integration inside Core
Process	P7	Backup manager inside Core
Data store	DS1	Configuration and integration secrets
Data store	DS2	Accounts hashes and token validation records
Data store	DS3	Zigbee keys device list and network state
Data store	DS4	Recorder state and event database
Data store	DS5	Encrypted local backup archive
Data store	DS6	Backup encryption key material
Data store	DS7	Local application logs
Data flow	DF1	EE1,EE2 to P1
Data flow	DF2	P1 to P2
Data flow	DF3	EE6 to P2
Data flow	DF4	P2 to P3
Data flow	DF5	P3 to P2
Data flow	DF6	P2 to P4
Data flow	DF7	P4 to P5
Data flow	DF8	P5 to EE3,EE4
Data flow	DF9	EE3 to EE3,EE4
Data flow	DF10	EE1 to P4
Data flow	DF11	EE5 to P4
Data flow	DF12	P2 to DS1,DS2
Data flow	DF13	P4 to DS3
Data flow	DF14	P2 to DS4
Data flow	DF15	P7 to DS1,DS2,DS3,DS4
Data flow	DF16	P7 to DS5,DS6
Data flow	DF17	P6 to P2,DS1-DS7
Data flow	DF18	P2,P4,P7 to DS7
Trust boundary	TB1	Flat household LAN to Core
Trust boundary	TB2	Core to USB coordinator and radio devices
Trust boundary	TB3	Core to manufacturer service (outbound)
Trust boundary	TB4	Unauthenticated / ordinary / administrator privileges

Associated findings
F-05, F-17, F-20
F-02, F-14, F-17, F-22
F-10, F-15, F-21, F-22, F-23
F-08, F-09, F-15, F-21, F-23
F-15
F-03, F-06
F-02, F-04
F-01, F-02, F-03, F-04, F-14, F-16, F-17, F-19, F-20
F-09, F-16, F-18
F-07, F-09, F-10, F-15, F-16
F-07, F-21 (no distinct threat to coordinator firmware itself: manual install, internals excluded)
F-01, F-11, F-12, F-13
F-12, F-13
F-01, F-13
F-01, F-13
F-01, F-13
F-09, F-13
F-01, F-12, F-13
F-01, F-12
F-11, F-19
No distinct threat identified
F-02, F-04, F-14, F-16, F-17, F-20
F-03, F-16
F-01, F-09
F-01, F-18
F-01, F-22
No distinct threat identified (physical USB access is out of scope)
F-07, F-09, F-10, F-21, F-23
F-10, F-23
F-05, F-07, F-14
F-15
F-01
F-01
F-01, F-09
No distinct threat identified (read path is trusted P7)
F-12, F-13
F-01, F-11, F-12, F-13
F-11, F-19
F-02, F-03, F-04, F-16
F-07, F-08, F-09, F-10, F-21, F-23
F-15
F-01, F-05, F-14